

1 # Municipal Data Center Security & Operations - Compliance Response
2 # Submitted by: Northern Shield Technologies
3 # Date: July 2026
4
5 ## Section 1: Physical Security
6
7 REQ-001 Response: Our facility maintains 24/7 security with two guards per shift. Patrol
schedules are documented in our Physical Security Plan (PSP-2026-03) with randomized
routes verified by guard tour system.
8
9 REQ-002 Response: All entry points use HID iCLASS SE readers (badge) combined with iris
recognition biometric scanners. Dual-factor is enforced at all times with no bypass
capability.
10
11 REQ-003 Response: 142 IP cameras cover all server rooms, corridors, loading docks, and
parking areas. Footage retained for 120 days on encrypted NVR storage exceeding the
90-day requirement.
12
13 REQ-004 Response: Visitors must be pre-approved 24 hours in advance via our visitor
management system. All visitors are issued temporary badges and escorted by authorized
personnel at all times.
14
15 REQ-005 Response: Primary data center entrance uses a Sally port (mantrap) with
interlocking doors, weight sensors, and tailgating detection. Anti-passback enforced on
all controlled doors.
16
17 REQ-006 Response: Schneider Electric NetBotz environmental monitoring deployed
throughout. Sensors cover temperature, humidity, water leak, and airflow. Alerts via
SMS, email, and BMS integration within 30 seconds.
18
19 REQ-007 Response: All server rooms use Novec 1230 clean agent fire suppression with
VESDA early detection. Systems tested semi-annually per NFPA 2001 with local fire
marshal oversight.
20
21 REQ-008 Response: Dual 2MW Caterpillar diesel generators with 96-hour fuel supply
on-site. Automatic transfer switches activate within 10 seconds of utility failure.
Monthly load bank testing documented.
22
23 REQ-009 Response: Physical access logs retained for 3 years in our Security Information
Management system. Reports can be generated within 1 hour for any audit request.
24
25 REQ-010 Response: All hardware disposal follows NIST SP 800-88 Rev. 1. We use on-site
degaussing for magnetic media and physical shredding for SSDs. Certificates of
destruction provided within 48 hours.
26
27 ## Section 2: Network Security
28
29 REQ-011 Response: Network segmented into Production (VLAN 100-199), Development (VLAN
200-299), and Management (VLAN 300-399). Inter-VLAN routing restricted by ACLs on Cisco
Nexus 9000 core switches.
30
31 REQ-012 Response: Palo Alto PA-5450 next-generation firewalls deployed at all perimeter
points. App-ID, threat prevention, URL filtering, and WildFire sandboxing active on all
policies.
32
33 REQ-013 Response: Cisco Secure IPS deployed inline at all network boundaries. Signature
updates hourly. Custom rules developed for Borough-specific traffic patterns.
34
35 REQ-014 Response: Cisco Umbrella DNS filtering with real-time threat intelligence.
Custom block lists for known adversary infrastructure. DNS over HTTPS blocked to prevent
bypass.
36
37 REQ-015 Response: All wireless networks use WPA3-Enterprise with EAP-TLS certificate
authentication issued from our internal PKI. No PSK networks permitted.
38
39 REQ-016 Response: Cisco ISE network access control verifies device certificates, OS

patch level, and EDR status before granting VLAN access. Non-compliant devices quarantined automatically.

REQ-017 Response: Dedicated out-of-band management network (VLAN 350) accessible only from Privileged Access Workstations via jump server. No management interfaces exposed on production VLANs.

REQ-018 Response: Cloudflare Magic Transit provides volumetric DDoS mitigation for all public IP space. Automatic activation within 3 seconds. On-premises Arbor Sightline for flow-based detection.

REQ-019 Response: NetFlow/IPFIX collected from all switches and firewalls. Data stored in Elastic cluster with 18-month hot retention. Full packet capture available for critical segments (30-day retention).

REQ-020 Response: Quarterly penetration tests conducted by NCC Group (CREST certified). Scope includes external perimeter, web applications, and social engineering. Reports delivered within 10 business days.

Section 3: Server & Endpoint Security

REQ-021 Response: All servers hardened to CIS Level 2 benchmarks using Ansible automation. Compliance validated weekly via Qualys Policy Compliance module with automated drift remediation.

REQ-022 Response: CrowdStrike Falcon deployed across all servers (Windows and Linux) and workstations. Falcon Complete MDR provides 24/7 monitoring and response.

REQ-023 Response: Critical patches applied within 7 days (exceeds 14-day requirement). High patches within 14 days. Monthly patch cycles for moderate/low with emergency out-of-cycle process documented.

REQ-024 Response: All servers use BitLocker (Windows) or LUKS (Linux) full-disk encryption. Keys escrowed in Thales Luna HSM (FIPS 140-2 Level 3, exceeding Level 2 requirement).

REQ-025 Response: Windows Firewall and iptables/nftables configured deny-all-inbound by default. Rules managed centrally via Ansible with change control. Monthly rule review documented.

REQ-026 Response: All administrative access conducted from hardened PAWs. PAWs are dedicated hardware with no internet access, application whitelisting, and enhanced logging.

REQ-027 Response: Golden images rebuilt monthly using HashiCorp Packer from CIS-hardened base. Images stored in versioned repository with SHA-256 integrity verification at deployment.

REQ-028 Response: OSSEC file integrity monitoring on all critical system files, binaries, and configuration files. Alerts trigger within 60 seconds of unauthorized change.

REQ-029 Response: Windows servers use AppLocker in enforce mode. Linux servers use fapolicyd. Both configured to allow only approved binaries from golden image plus explicitly approved additions.

REQ-030 Response: Group Policy and Linux udev rules disable all USB mass storage across servers. Exceptions require CISO approval with time-limited enablement and enhanced logging.

REQ-031 Response: All certificates use 4096-bit RSA or 384-bit ECC keys (exceeds requirement). Certificate lifecycle managed via Venafi Trust Protection Platform.

REQ-032 Response: Qualys VMDR runs authenticated scans weekly against all internal systems. Critical findings auto-create Jira tickets assigned to system owners with SLA tracking.

REQ-033 Response: CrowdStrike sensor updates continuously (cloud-based). Definitions typically update within minutes of release. Fallback offline definitions update every 2 hours.

REQ-034 Response: All systems forward logs to Splunk Enterprise via syslog-TLS in real-time. Local logging disabled on production systems. Log delivery confirmed via heartbeat monitoring.

REQ-035 Response: Container images scanned at build (Snyk in CI/CD pipeline) and runtime (CrowdStrike Falcon Container). Images with critical vulnerabilities blocked from deployment via admission controller.

Section 4: Identity & Access Management

REQ-036 Response: All accounts use unique employee ID-based naming convention. Shared accounts prohibited by policy and detected by automated scanning. Service accounts use managed identities.

REQ-037 Response: MFA enforced for all remote access (VPN, RDP) and all privileged operations. Microsoft Entra ID with FIDO2 hardware keys for privileged accounts, push notification for standard users.

REQ-038 Response: Password policy enforces minimum 20 characters (exceeds 16-char requirement). Complexity requires uppercase, lowercase, number, and special character. Passwords checked against breach databases.

REQ-039 Response: CyberArk Privileged Access Manager provides just-in-time elevation with maximum 4-hour sessions (exceeds 8-hour limit). All sessions recorded and available for review.

REQ-040 Response: Azure Managed Identities used for all Azure-hosted services. On-premises service accounts use gMSA with automatic 30-day password rotation. No static passwords in production.

REQ-041 Response: Quarterly access reviews conducted via SailPoint IdentityIQ. Reviews cover all systems with privileged access. Non-responsive reviews auto-revoke after 14 days.

REQ-042 Response: RBAC implemented across all systems with role definitions reviewed semi-annually. Custom roles follow least privilege principle with no standing admin access.

REQ-043 Response: Automated provisioning/deprovisioning via SailPoint triggers from Workday HR system. Average completion time: 23 minutes for provisioning, 12 minutes for deprovisioning (well within 4 hours).

REQ-044 Response: Account lockout triggers after 5 failed attempts with 15-minute automatic unlock (more restrictive than 30-minute requirement). Progressive delays implemented for repeated lockouts.

REQ-045 Response: All authentication events (success, failure, MFA challenge, token issuance) logged to Splunk SIEM with correlation rules for impossible travel, brute force, and credential stuffing.

REQ-046 Response: Conditional access policies enforce: US-only login for admin accounts, device compliance (Intune managed, current patches), and risk-based step-up authentication via Identity Protection.

REQ-047 Response: Two break-glass accounts maintained in sealed envelopes in the physical safe. Usage triggers immediate PagerDuty alert to security team. Tested quarterly with documented results.

REQ-048 Response: Third-party access uses dedicated accounts in isolated OU with 24-hour maximum session. Enhanced logging and real-time session monitoring via CyberArk PSM.

109 REQ-049 Response: All APIs authenticate via OAuth 2.0 with Azure AD B2C. Access tokens
expire in 15 minutes (well under 1-hour maximum). Refresh tokens expire in 8 hours.

110

111 REQ-050 Response: Azure AD Connect cloud sync runs every 2 minutes (exceeds 5-minute
requirement). Critical changes (disable, delete) propagate within 30 seconds via
on-demand sync trigger.

112

113 ## Section 5: Data Protection

114

115 REQ-051 Response: Four-tier classification implemented: Public, Internal, Confidential,
Restricted. All data classified at creation via Microsoft Purview auto-labeling with
manual override capability.

116

117 REQ-052 Response: AES-256 encryption at rest for all Confidential and Restricted data.
Implemented via platform encryption (Azure, SQL TDE) and application-layer encryption
for sensitive fields.

118

119 REQ-053 Response: TLS 1.3 enforced for all communications. TLS 1.2 accepted only for
legacy systems with documented exception and migration timeline. TLS 1.1 and below
completely disabled.

120

121 REQ-054 Response: Imperva Database Activity Monitoring deployed on all production
databases. Alerts on: bulk SELECT (>1000 rows), schema changes, after-hours access, and
new query patterns.

122

123 REQ-055 Response: Microsoft Purview DLP policies cover: Exchange email,
SharePoint/OneDrive, Teams, Edge browser uploads, USB transfers, and third-party cloud
apps via Defender for Cloud Apps.

124

125 REQ-056 Response: Backups encrypted with AES-256 using dedicated backup encryption keys.
Replicated to Azure West US 2 region (1,400+ miles from primary). Integrity verified
weekly via restore tests.

126

127 REQ-057 Response: Retention policies implemented in Microsoft Purview Records Management
aligned to Borough schedule. Automated disposition with approval workflow. Defensible
deletion with audit trail.

128

129 REQ-058 Response: All non-production environments use tokenized data generated by
Delphix. No actual PII present in dev/test. Data masking verified quarterly by
compliance team.

130

131 REQ-059 Response: Azure Policy prevents resource creation outside US regions.
Cross-border transfer requests require legal review via ServiceNow workflow. No
exceptions granted to date.

132

133 REQ-060 Response: Encryption keys rotate automatically every 60 days (exceeds 90-day
requirement) via Azure Key Vault. Immediate revocation capability tested monthly. Key
ceremonies require dual control.

134

135 ## Section 6: Incident Response & Continuity

136

137 REQ-061 Response: Incident Response Plan (IRP-2026-v4) maintained and reviewed every 6
months. Last tabletop exercise conducted May 2026 simulating ransomware scenario. Next
scheduled September 2026.

138

139 REQ-062 Response: Critical incidents reported to Borough leadership within 1 hour
(exceeds 2-hour requirement). Automated alerting via PagerDuty escalation chain to CIO
and CISO simultaneously.

140

141 REQ-063 Response: Forensic procedures documented in Digital Forensics Playbook
(DFP-2026-v2). All security analysts GCFE certified. Annual training includes evidence
handling, chain of custody, and court testimony preparation.

142

143 REQ-064 Response: Tier 1 systems achieve 2-hour RTO (exceeds 4-hour requirement) via
active-passive failover. Validated quarterly through automated failover testing with
rollback verification.

144

145 REQ-065 Response: DR failover tested quarterly. Last test (June 2026) achieved full
recovery in 1:47:23. Two findings identified and remediated within 5 business days. Full
report available for review.

146